

Incident Response Engagement Findings & Detection Report

INC-2026-002 - Privilege Escalation & Persistence

CLIENT

NexaCorp Industries

Root-level compromise of bru-app-01 (Brussels)

Engagement reference INC-2026-002

Phase 1 forensic analysis & Phase 2 live SIEM validation

Prepared by

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 27 May 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
EXECUTIVE SUMMARY	4
METHODOLOGY	6
INCIDENT TIMELINE	8
TECHNICAL ANALYSIS	9
F1 Reconnaissance over Tor (diversion)	9
F2 Initial access via stolen SSH key	10
F3 Privilege escalation via SUID find	11
F4 Credential dump (/etc/shadow)	12
F5 Backdoor account (it_support)	13
F6 SSH private-key harvesting	14
F7 Cron persistence (svc-updater)	15
RISK MATRIX	16
MITRE ATT&CK MAPPING	17
PHASE 2: LIVE DETECTION (WAZUH)	18
REMEDATION	20
TOOLS AND STANDARDS	21
GLOSSARY AND ACRONYMS	23

Confidentiality Statement

This report documents INC-2026-002 of the BeCode Corp internal cybersecurity training programme, an incident response engagement against a controlled laboratory environment simulating a privilege-escalation and persistence incident on the fictitious organisation NexaCorp's Brussels application server. No real production system, customer data, or third party was involved. All identities, hostnames and accounts referenced belong to the BeCode training environment.

This document is classified Confidential under reference BCC-2026 | INC-2026-002. Raw evidence is retained by BeCode Corp and is not redistributed. Publication for portfolio use was authorized by the BeCode lab coach (Thomas B.) on 2026-05-17.

Disclaimer

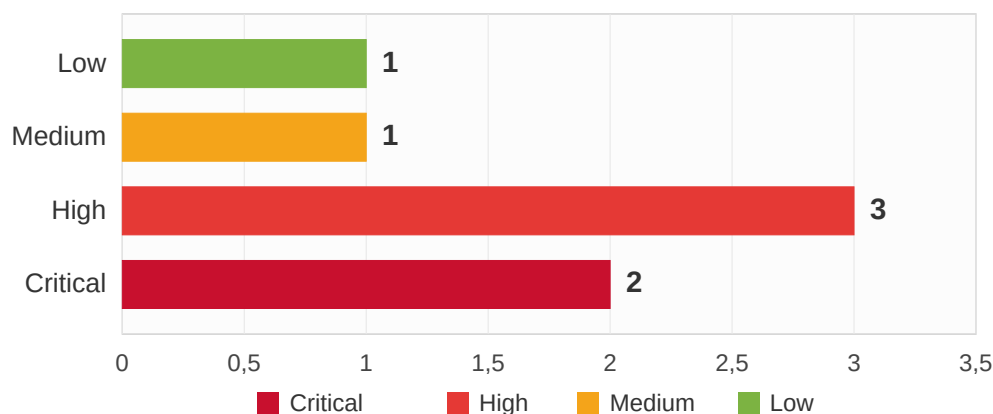
Phase 1 findings are based on the evidence bundle (auth.log, audit.log, syslog, cron.log, incident metadata) covering 2026-05-16 ; the bundle is pre-filtered to svc_api activity. Phase 2 validation used a MITRE Caldera adversary profile replayed against the live target under Wazuh. The methodology follows NIST SP 800-61r2 and the SANS PICERL process. All timestamps are local Brussels time (CEST, UTC+02:00) unless indicated.

Executive Summary

On the night of 16 May 2026, a threat actor compromised bru-app-01, NexaCorp's Brussels internal application server. The attacker authenticated as the service account `svc_api` using a stolen SSH private key (over Tor), escalated to root via a misconfigured SUID bit on `/usr/bin/find`, dumped credential material (`/etc/shadow`), harvested SSH keys, created a backdoor account (`it_support`), and installed a cron-based persistence mechanism.

The intrusion is the direct continuation of INC-2026-001 (Liege) : the SSH key used here was almost certainly harvested during the prior compromise, so both must be treated as one coordinated campaign. Three persistence vectors remain potentially active until remediated : the original SSH key (if not rotated), the `it_support` backdoor, and the `/etc/cron.d/svc-updater` cron file. A Phase 2 live Wazuh run validated detection of the credential dump and the backdoor account, but exposed a critical blind spot on the cron persistence.

Findings by Severity Level

**B.**

Overview of findings

Ref	Description	Severity
F1	Account enumeration over Tor (diversion, failed logins)	LOW
F2	Initial access via stolen svc_api SSH key over Tor (40 beacon logins)	HIGH
F3	Privilege escalation via SUID /usr/bin/find (GTF0Bins)	CRITICAL
F4	Credential dump: /etc/shadow read 27 times	HIGH
F5	Backdoor local account it_support created	HIGH
F6	SSH private-key harvesting (lateral-movement prep)	MEDIUM
F7	Cron persistence /etc/cron.d/svc-updater	CRITICAL

Overview of recommendations

REF	FINDING	SHORT RECOMMENDATION
F2/F6	Stolen and harvested keys	Rotate the <code>svc_api</code> key on every host; audit <code>authorized_keys</code> network-wide for trust from <code>bru-app-01</code> .
F3	SUID find	Remove the SUID bit (<code>chmod u-s /usr/bin/find</code>); baseline all SUID binaries against Debian 12.
F5/F7	Backdoor + cron	Remove <code>it_support</code> and <code>/etc/cron.d/svc-updater</code> ; force a password reset for every account (shadow dumped).
Detection	Wazuh gaps	Deploy the <code>cron-persistence</code> rule (100205) and the <code>SUID</code> rule (100203); tune 100201/100202 on <code>exe/args</code> .

Methodology

A. Procedure

The investigation follows NIST SP 800-61r2 and the SANS PICERL process, mapping every finding to MITRE ATT&CK Enterprise v15. It is a two-phase engagement : Phase 1 forensic log analysis, Phase 2 live detection validation in Wazuh using a Caldera adversary profile.

01. Timeline reconstruction

- Reconstruct authentication events from auth.log
- Separate the Tor diversion from the real publickey access



02. Privilege-escalation analysis

- Trace SUID find escalation in audit.log (uid=1000, euid=0)
- Decode process titles to recover the six chained commands



03. Post-exploitation mapping

- Confirm the /etc/shadow dump, backdoor account and key harvest
- Cross-correlate with the incident metadata



04. Phase 2 live detection

- Replay a Caldera adversary profile under Wazuh
- Score detection coverage per task and identify gaps



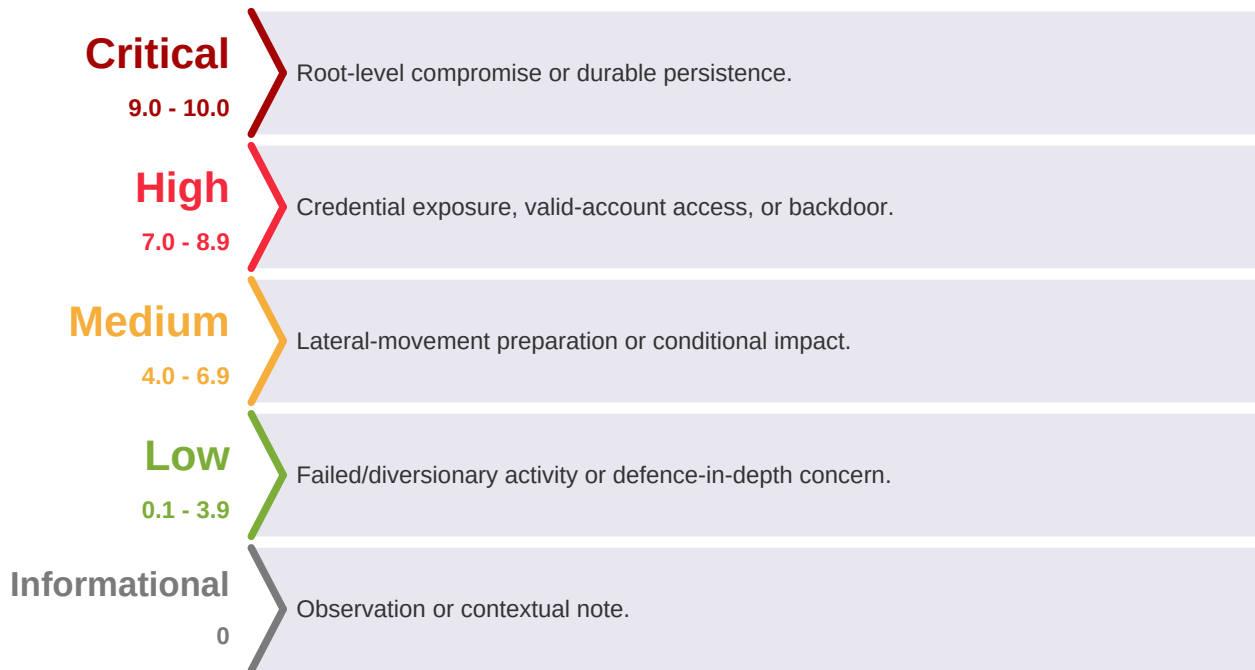
05. Consolidation and reporting

- Map findings to MITRE ATT&CK;
- Consolidate IOCs, remediation and detection improvements



B. Severity ratings

Severities are analyst-rated for this forensic context (impact, MITRE technique category, and current threat state), not CVSS-derived : CVSS scores discoverable vulnerabilities, not post-compromise forensic findings.



Incident Timeline

Timestamps local (CEST, UTC+02:00). The audit.log coverage starts later than the escalation reference (logging gap) ; earlier events are confirmed via auth.log and the incident metadata.

<i>Time (CEST)</i>	<i>Event</i>	<i>Source</i>
16 May 17:43:43	Initial access: SSH publickey as svc_api from 185.220.101.68 (Tor)	auth.log
17:45:14 - 19:41:06	Brute-force diversion: 39 failed logins on non-existent accounts (Tor)	auth.log
17:43:43 - 19:42:37	40 successful publickey logins (~3-min beacon, rotating Tor IPs)	auth.log
19:43:01	Privilege escalation reference moment (SUID find)	metadata
19:47:07	Backdoor account it_support created (useradd + chpasswd)	auth.log
~19:47 (per metadata)	Cron persistence /etc/cron.d/svc-updater installed	metadata, cron.log
22:47:02 - 23:41:54	55 SUID find events; 27 /etc/shadow reads; 54 id_rsa sweeps (audit window)	audit.log

Technical Analysis

F1 Reconnaissance: account enumeration over Tor (diversion)

Severity:

LOW

Finding type:

Account enumeration over Tor (failed, diversionary)

CVSS v3.1 base score:

N/A (failed attempts, diversion)

CWE:

CWE-307 (Improper Restriction of Excessive Authentication Attempts)

MITRE ATT&CK:

T1595.002, T1110.001

Affected scope:

- bru-app-01 SSH service
-

Description:

Between 17:45:14 and 19:41:06, 39 SSH authentication failures targeted 8 NexaCorp-style usernames from 36 Tor exit IPs across 5 /24 blocks, capped at 2 attempts per IP (below fail2ban thresholds). This is account enumeration, not brute force ; the username list shows prior knowledge of NexaCorp naming, consistent with INC-2026-001.

Why it matters:

The probing runs in parallel with the successful publickey logins (F2) : the strongest single indicator that the failed attempts are a diversion while the attacker was already inside through a different channel.

Evidence:

```
grep 'Failed password' auth.log | wc -l          # 39
grep 'Failed password' auth.log | grep -oE 'from [0-9.]+' | sort -u  # 36 Tor IPs
```

F2 Initial access via stolen svc_api SSH key over Tor

Severity:**HIGH**

Finding type:

Valid-account access via a stolen SSH private key

CVSS v3.1 base score:

8.1 (High) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CWE:

CWE-522 (Insufficiently Protected Credentials)

MITRE ATT&CK:

T1078.003, T1133, T1572

Affected scope:

- account svc_api (uid=1000)
-

Description:

At 17:43:43 the attacker authenticated by SSH public key as svc_api from a Tor exit (185.220.101.68), then performed 40 successful publickey logins to 19:42:37, all the same key fingerprint, all from 185.220.101.0/24, at a regular ~3-minute interval too regular for human activity : an automated beacon over Tor. The key was not brute-forced ; it was a valid key the attacker should not have possessed, most plausibly harvested during INC-2026-001.

Why it matters:

A persistent low-privilege foothold held for ~2 hours before escalation, with command-and-control tunnelled through Tor.

Evidence:

```
grep 'Accepted publickey' auth.log | wc -l          # 40
grep 'Accepted publickey' auth.log | grep -oE 'SHA256:[A-Za-z0-9+/=]+' | sort -u  # single
fingerprint
```

F3 Privilege escalation via SUID /usr/bin/find

Severity:

CRITICAL

Finding type:

Privilege escalation via SUID misconfiguration (GTF0Bins)

CVSS v3.1 base score:

7.8 (High base, Critical in context) - AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

CWE:

CWE-250 (Execution with Unnecessary Privileges), CWE-732

MITRE ATT&CK:

T1548.001, T1057, T1083

Affected scope:

- /usr/bin/find (mode 0104755) on bru-app-01

Description:

The audit log shows 55 events tagged key=suid_escalation, every one with uid=1000 (svc_api) and euid=0 (root). The attacker abused the SUID bit on /usr/bin/find (a GTF0Bins technique) for automated root-level read access, chaining six commands at ~60-second intervals (ps aux, log searches, /etc/shadow reads, id_rsa sweeps) : a deployed beacon, not interactive use.

Root cause:

Standard Debian 12 does not ship find with the SUID bit. It was set manually (admin automation) or by the attacker ; either way it is the primary vulnerability enabling root compromise.

Evidence:

```
grep '/usr/bin/find' audit.log | grep 'key="suid_escalation"' | wc -l    # 55
grep 'type=PROCTITLE' audit.log | ... | sort | uniq -c    # 6 unique chained commands
```

F4 Credential dump: /etc/shadow

Severity:

HIGH

Finding type:

OS credential dumping (/etc/shadow)

CVSS v3.1 base score:

7.5 (High) - AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N

CWE:

CWE-522 (Insufficiently Protected Credentials)

MITRE ATT&CK:

T1003.008

Affected scope:

- /etc/shadow on bru-app-01
-

Description:

/etc/shadow was read 27 times via direct cat, plus 27 invocations wrapped in bash -c with head -3 piping and redirection, consistent with hash exfiltration over the active SSH session. Every password hash on bru-app-01 must be assumed in the attacker's hands and crackable.

F5 Backdoor local account it_support

Severity:**HIGH**

Finding type:

Persistence via a backdoor local account

CVSS v3.1 base score:

8.0 (High) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CWE:

CWE-269 (Improper Privilege Management)

MITRE ATT&CK:

T1136.001

Affected scope:

- account it_support (uid=1002)
-

Description:

At 19:47:07 the attacker created a local user it_support (useradd), with a password set 50 ms later via chpasswd. The name is deliberate social engineering : it reads like a legitimate internal IT account, blending into a quick administrative review. The metadata mentions sudo rights (to validate on the live system).

Why it matters:

A standalone administrative login independent of the stolen key, surviving a key rotation.

Evidence:

```
grep -i 'useradd\\|new user\\|chpasswd' auth.log # it_support created 19:47:07, password 19:47:07.527
```

F6 SSH private-key harvesting (lateral-movement prep)

Severity:

MEDIUM

Finding type:

Systematic SSH private-key search

CVSS v3.1 base score:

N/A (preparation, no confirmed onward use in this incident)

CWE:

CWE-522 (Insufficiently Protected Credentials)

MITRE ATT&CK:

T1552.004

Affected scope:

- /home/*/ssh/id_rsa, /root/.ssh

Description:

The attacker ran `find /home -name id_rsa` 54 times, sweeping every user home, and enumerated `/root/.ssh` via a bash wrapper. This is classic lateral-movement preparation : any private key found grants access to other hosts trusting it, with no further credential discovery.

Operational implication:

Any host whose `authorized_keys` trusts a key whose private counterpart was on `bru-app-01` must be treated as potentially compromised ; a network-wide trust-relationship audit is required.

F7 Scheduled-task persistence (/etc/cron.d/svc-updater)

Severity:

CRITICAL

Finding type:

Persistence via a scheduled task (cron drop-in)

CVSS v3.1 base score:

N/A (forensic finding, Phase 2 confirmed)

CWE:

CWE-732 (Incorrect Permission Assignment for Critical Resource)

MITRE ATT&CK:

T1053.003

Affected scope:

- /etc/cron.d/svc-updater on bru-app-01
-

Description:

The metadata states the attacker installed /etc/cron.d/svc-updater (every 10 minutes). Phase 1 direct proof is incomplete (the cron install fell in the 17:43-22:47 window before audit.log coverage, and the logs do not record file writes), but the file was confirmed on the running system during Phase 2. It is a durable, self-restoring persistence mechanism.

Detection note:

No Wazuh rule watched /etc/cron.d/ at the time : Phase 2 confirmed this as the most significant detection gap (see Phase 2 section, rule 100205 proposed and deployed to close it).

Risk Matrix

Each finding plotted by Impact against Likelihood. Upper-right is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				F3	F7
High (4)			F4	F2, F5	
Medium (3)			F6		
Low (2)				F1	
Very Low (1)					

Critical	High	Medium	Low
----------	------	--------	-----

F7 (cron persistence) and F3 (root via SUID find) are Critical ; F2 (stolen key), F4 (shadow dump) and F5 (backdoor) are High ; F6 (key harvest) is Medium and F1 (Tor diversion) is Low.

MITRE ATT&CK Mapping

<i>Finding</i>	<i>Tactic</i>	<i>Technique ID</i>	<i>Technique Name</i>
F1	Reconnaissance / Credential Access	T1595.002, T1110.001	Active Scanning; Brute Force: Password Guessing
F2	Initial Access / C2	T1078.003, T1133, T1572	Valid Accounts; External Remote Services; Protocol Tunneling
F3	Privilege Escalation / Discovery	T1548.001, T1057, T1083	Setuid/Setgid; Process and File Discovery
F4	Credential Access	T1003.008	OS Credential Dumping: /etc/passwd and /etc/shadow
F5	Persistence	T1136.001	Create Account: Local Account
F6	Credential Access	T1552.004	Unsecured Credentials: Private Keys
F7	Persistence	T1053.003	Scheduled Task/Job: Cron

Framework : MITRE ATT&CK Enterprise v15.

Phase 2: Live Detection in Wazuh

A MITRE Caldera adversary profile (lab2-linux-privesc) was replayed against the live target under Wazuh on 2026-05-27, generating 13 attributable alerts over ~5.5 minutes. Caldera runs as a root systemd agent, so it skips the initial-access and SUID-escalation phases and exercises only post-root activity (a known limitation of adversary emulation).

A. Detection coverage per task

<i>Task</i>	<i>Wazuh rule</i>	<i>Alerts</i>	<i>Verdict</i>
4A: /etc/shadow dump	100201	2	Effective
4B: useradd backdoor	100202	2	Effective
4C: SSH key harvest	100204	9	Imprecise (fires as a side effect of SUID enum)
4D: cron persistence	(none)	0	Critical gap (no rule watched /etc/cron.d/)

Tasks 4A and 4B fire on real attack activity. Task 4C is detected only because SUID enumeration traverses .ssh directories (it mischaracterizes the activity). Task 4D is a complete blind spot : the cron persistence (the technique used by this incident) triggered nothing.

B. Rule status and improvements

<i>Rule</i>	<i>Type</i>	<i>Status</i>	<i>Purpose</i>
100201	Tuning	Deployed	/etc/shadow access, excluding Wazuh FIM and cron daemon noise
100202	Tuning	Deployed	useradd backdoor, excluding the read-only useradd -D inventory call
100205	New rule	Deployed	Cron persistence: fires on writes to /etc/cron.d/ (closes the 4D gap)
100203	New rule	Proposed	SUID escalation: uid!=0 with euid=0 (closes the Phase 1 Task 3 gap)

A noted pitfall : filtering on `audit != unset` would suppress the daemon false positives but ALSO the real Caldera-detected events (both share `audit=4294967295`). The correct discriminator for this architecture is the executable path and arguments, not the audit UID. The full rule XML and false-positive analysis are in the `detection/` folder.

Remediation

Critical (do immediately)

- Rotate the svc_api SSH key on every host where it is provisioned; audit authorized_keys network-wide.
- Remove the backdoor user it_support (userdel -r) and audit other UIDs >= 1000 with recent home creation.
- Remove the cron persistence (rm /etc/cron.d/svc-updater) and audit all /etc/cron.* and per-user crontabs.
- Force a password reset for every account on bru-app-01 (the shadow file was dumped).
- Remove the SUID bit on /usr/bin/find (chmod u-s) and baseline all SUID binaries against Debian 12.

Short to medium term

- Block Tor exit nodes for inbound SSH; restrict svc_api SSH to internal source IPs (Match User / AllowUsers).
- Inventory lateral exposure: every host trusting a key from bru-app-01 is potentially compromised; re-deploy bru-app-01 from a clean baseline.
- Ensure auditd runs from boot with tamper-resistant shipping to Wazuh.
- Deploy the cron-persistence (100205) and SUID (100203) rules, and the 100201/100202 tunings, in Wazuh.

Tools and Standards

A. Tools used during the engagement

<i>Category</i>	<i>Tool</i>	<i>Purpose</i>
Log analysis	grep / awk / sort / uniq / xxd	Reconstruct the timeline and decode audit process titles
SIEM	Wazuh	Phase 2 live detection validation and rule tuning
Adversary emulation	MITRE Caldera	Replay the post-exploitation TTPs against the live target
Auditd	Linux audit daemon	Syscall recording (key-tagged shadow_access, useradd, suid_escalation, ssh_keys)
Documentation	VS Code, Markdown	Note-taking and report drafting

B. Standards and frameworks followed

<i>Standard / Framework</i>	<i>Version</i>	<i>Application</i>
NIST SP 800-61r2	2012	Incident handling methodology
NIST SP 800-86	2006	Forensic technique integration
SANS PICERL	-	Incident response phases
MITRE ATT&CK Enterprise	v15	Technique mapping
MITRE Caldera	-	Phase 2 adversary emulation
CWE	v4.16	Root-cause classification (CWE-250, 269, 522, 732)

Glossary and Acronyms

<i>Acronym</i>	<i>Full Name</i>	<i>Description</i>
SUID	Set User ID	Permission bit that runs a binary with the owner's privileges
GTFOBins	Get The F*** Out Binaries	Unix binaries abusable to escalate privileges (e.g. find)
SSH	Secure Shell	Encrypted remote-administration protocol
Tor	The Onion Router	Anonymity network used here to mask the attacker source
cron	cron daemon	Unix scheduler; /etc/cron.d/ holds drop-in job files
auditd	Linux Audit daemon	Records syscalls; key-tagged rules label events of interest
audit / euid	Audit / Effective User ID	audit is the login identity; uid=1000 with euid=0 marks an escalation
Caldera	MITRE Caldera	Adversary-emulation platform used in Phase 2
Wazuh	Wazuh	Open-source SIEM/XDR used for live detection
IOC	Indicator of Compromise	Artifact pointing to malicious activity
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat behaviour framework
CWE	Common Weakness Enumeration	Classification of software and configuration weaknesses

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-002

Classification: Confidential

Analyst

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi